

HTCS6702 Cryptography

Assessment Part 1: Teamwork

By Young Kwang Kweon, Luis Suarez Lopez

Table of contents

3	<u>Introduction</u>
4	<u>Task 1: Obligations</u>
4	<u>Business Obligations for end-user information</u>
6	<u>Regulatory Obligations for end-user information</u>
10	<u>Task 2: Security requirements</u>
10	<u>Concepts of data integrity</u>
11	<u>Concepts of authentication mechanisms</u>
13	<u>Task 3: Test platform</u>
13	<u>Question 1: Client-server platform</u>
15	<u>Question 2: Platform design</u>
16	<u>Question 3: Symmetric key management algorithm</u>
17	<u>Question 4: Key distribution</u>
17	<u>Question 5: Two access control models</u>
18	<u>Question 6: Access control model to the system</u>
19	<u>Conclusion</u>
20	<u>References</u>

Introduction

In this report, we have analysed and designed a system that allows end-users to access their information remotely for the New Zealand-based company, 'Phone-me'. All the end-user data will be saved in the physical server of Phone-me and in the AWS server that the company uses, and not in the users' devices. To gain access to the company's server, we have proposed a two-factor authentication method to implement in the company's system. Before Phone-me can launch our designed platform, they need to consider obligations and security requirements that comply with the required obligations.

Task 1 covers what obligations that Phone-me needs to consider in their platform. They need to comply with business obligations including inside New Zealand and obligations of all the services they use (i.e. AWS) and regulatory obligations of New Zealand laws.

Task 2 covers security requirements. In this section, we discuss how data integrity is ensured and how the authentication method is implemented to the company's platform.

Task 3 covers our proposed design architecture for the company's platform based on their security needs. The platform will use various AWS services to ensure data integrity, provide two-factor authentication, and transfer customer data from AWS server to the company's own physical server for back-up.

We hope our analysis and design will help Phone-me to successfully set up the platform securely and meet your needs.

Task 1: Business Obligations and Regulatory Obligations for end-user information security

Business Obligations

In the context of the client system that "Phone-me" wishes to implement, we will identify some business obligations that the company must consider when implementing this system.

The Chief Technology Officer (CTO) has informed the team designing the system to consider two customer obligations:

- End-user data must not be stored on the client.
- A two-factor security password must be used.

For this case, the business obligations to be identified are:

1. Protection of Customer Confidence

Phone-me must keep customer information safe and secure. It must allow users access to the information it holds about them and take reasonable steps to correct it if it is incorrect. (Privacy Commissioner, n.d.)

Phone-me must also monitor information in transit, in this case, the information users enter through our website. This involves taking measures to prevent unauthorized or inappropriate access by external agents or company personnel. (Privacy Commissioner, n.d.)

It is also necessary to implement clear policies and guidelines that establish how personnel handle information, and systems must be implemented to limit or track who accesses that information. (Privacy Commissioner, n.d.)

2. Service Availability and Security

The service must be available to users without compromising security. Phone-me requires strong authentication, such as multi-factor authentication, to protect access. Users will not be able to access these services without MFA. (CERT NZ, n.d.)

The systems that Phone-me uses to manage and operate the authentication module (e.g. Amazon Cognito) must be kept up to date. All dependencies related to the module must also be updated, and the infrastructure where the module runs must be hardened; for example, unused ports must be blocked and patched. (CERT NZ, n.d.)

The company must implement internal processes to verify who receives external requests or has access to data. Report and log all security events and unauthorized requests as part of Phone-me's security incident management process. (CERT NZ, n.d.)

3. Compliance with AWS security policies

By using AWS for cloud storage, Phone-me is required to follow the provider's recommended security practices, such as using AWS Cognito, an identity platform for web or mobile applications. Cognito will handle all end-user authentication and authorization. (AWS, n.d.)

The AWS Identity and Access Management (IAM) web service will also be used to manage internal users and AWS services and thus securely control access to the web application's resources. (AWS, n.d.)

Additionally, for encryption in transit and at rest, Amazon recommends using AWS Key Management Service (AWS KMS), which facilitates the creation and control of encryption keys used to encrypt data. (AWS, n.d.)

4. Security Incident Management and Response

Phone-me must have an incident response plan to mitigate any unauthorized access, including early detection, notification, and traceability. (CERT NZ, n.d.)

The company must have an ongoing security training and awareness program that keeps staff informed about expected reporting processes, threats, and current issues. (CERT NZ, n.d.)

Regulatory obligations

Regulatory obligations are standards according to laws set by government authorities that an individual or organisations must comply with. These obligations are designed to guide safe, transparent and fair practices and operations for the business.

In terms of end-user information security, as a telecommunication provider in New Zealand, Phone-me company must consider the following regulations:

1. Privacy Act 2020

New Zealand Privacy Act of 2020 is a legislation in New Zealand that governs the collection, use, storage and disclosure of personal information. Under this act, there are 13 key privacy principles ("Privacy Act 2020", 2021) and Phone-me must comply with principle 5:

Principle 1, Purpose for collection:

Personal information is collected for lawful purposes, and the information is necessary for that purpose.

To gain access to Phone-me's services, users must create their own account.

Principle 2, Source of information - collection from the individual:

Personal information is directly collected from the person who gives you permission.

When the user creates an account on Phone me from Phone-me's homepage, he/she will be asked to provide first name, surname, phone number, email address, and password.

Principle 3, What to tell the individual about collection:

Make sure that the person whose information is being collected knows why it's being collected, who will receive it, giving information is compulsory or voluntary, and the consequence(s) of not providing the information.

In Phone-me's homepage, there will be a privacy policy listed on terms & conditions page. It will mention why the personal data is collected – to provide services, which third-parties it may be shared and why – NZ Police to prevent fraud and Amazon because user information is stored in AWS, and user record IP addresses and calls for the monitoring and investigation purposes.

Principle 4, Manner of collection:

Information is collected in a way that is lawful, fair, not intrusive, and takes particular care when collecting personal information about children.

Principle 5. Storage and security of information:

Have security in place to prevent loss, misuse, or disclosure of personal information.

To login to Phone-me's account from the website, two-factor authentication will be applied, and user data will be stored in a secure cloud-based server, not in the users' devices.

Principle 6. Providing people access to their information:

People have a right to ask for access to their personal information. But in some cases, you can refuse access if the people's purpose is inappropriate such as endangering other's safety.

Users of Phone-me service can login with mobile phones and from websites. There will be a profile page where users can view their personal information. But if the user has breached the regulations, Phone-me will block login access of that user.

Principle 7. Correction of personal information:

People have a right to ask organisation to correct their information if they think it is wrong.

Users of Phone-me service can change their personal information from the website at any time.

Principle 8. Ensure accuracy before using information:

Before using or disclosing personal information, organisation must ensure that the information is accurate, complete, relevant, up to date and not misleading.

When the user makes Phone-me account from the registration page, there will be sections where it asks the user to re-type email address and password. Before completion of registration, when the user clicks submit, it will prompt the user to check if your information is correct.

Principle 9. Limits on retention of personal information:

You must not keep the personal information for longer than is necessary.

If the user decides to discontinue Phone-me service, they will need to give the company at least 3 weeks of notice. Then phone-me can proceed with the termination of user account and remove user information from Phone-me's database. After successful termination, the user will be notified via email.

Principle 10. Use of personal information:

Personal information is only used for the original purpose you collected unless the person who provided the information gives you permission.

Phone-me will only use user information for the purposes mentioned in terms & conditions but there will be times asking for other information like home address or alternate phone numbers to communicate with user if Phone-me is unable to communicate with the methods from the user information page (email, mobile phone number) as long as the user consents to collecting other information.

Principle 11, Disclosing personal information:

Personal information can only be disclosed in limited circumstances. For example, disclosing information is necessary to avoid endangering someone's safety.

Phone-me may disclose user information to NZ Police for criminal investigation if the user violates the company's terms and conditions or use Phone-me's service for frauds, voice phishing or anything that violates New Zealand legislations.

Principle 12, Disclosure outside New Zealand:

Personal information can be sent overseas only if the information is protected.

Because Phone-me uses AWS to store user information in cloud, Phone-me user information will be shared with Amazon. "Using offshore cloud providers or other agents to store or process your data is not treated as a disclosure under principle 12" (" Sending information overseas", 2021)

Principle 13, Unique identifiers:

A unique identifier refers to a number or code that identifies a person. It is used for organisation's operation.

Each user of Phone-me will be given a unique Phone-me ID after registration and sent to their email. Users cannot edit their unique ID, and it will be used for uniquely identifying the person related to Phone-me.

2. Crimes Act 1961

Under New Zealand's 'Crimes Act 1961', section 249, 250, and 252 defines criminal offenses related to unauthorised access to or interference with computer systems.

Section 249: Accessing computer system for dishonest purpose

Liable to imprisonment for who, directly or indirectly, accesses any computer system and thereby, dishonestly or by deception, and without claim of right (The Parliamentary Counsel Office, 2003).

Section 250: Damaging or interfering with computer system

Liable to imprisonment for who without authorisation, intentionally damages, deletes, modifies, or otherwise interferes with or impairs any data or software in any computer system (The Parliamentary Counsel Office, 2003).

Section 252: Accessing computer system without authorisation

Liable to imprisonment for who intentionally accesses, directly or indirectly, any computer system without authorisation, knowing that he or she is not authorised to access that computer system, or being reckless as to whether or not he or she is authorised to access that computer system (The Parliamentary Counsel Office, 2003).

To prevent unauthorised access, Phone-me needs to implement a strong authentication method by ordering customers to make strong passwords, ensuring only authorised Phone-me staff and users can access sensitive data based on access control is configured.

Task 2: The concepts of data integrity and authentication mechanism(s) for the organisation's Security Requirements

Data integrity

A fundamental principle for Phone-me is data integrity. It is essential for the company to ensure that data cannot be altered or manipulated during transmission or storage without authorisation.

For the design of this new Phone-me client system, it is essential to ensure that any modification is immediately detected, as customer personal data and subscriptions are highly sensitive. Storing data in an architecture based on the AWS cloud service and allowing remote access poses risks during data transmission, such as a man-in-the-middle attack or accidental data corruption.

To avoid unnecessary risks, the new Phone-me client system will feature the following security mechanisms:

- **Cryptographic hash functions (SHA-256):** When data is sent from the client to the server, a unique hash is generated using the SHA-256 function. This hash is compared at both ends to confirm that the information has not been modified in transit. SHA-256 is widely used due to its collision resistance, meaning that SHA-256, by its very nature, prevents two different inputs from generating the same hash. Additionally, it is a recommended practice for protecting passwords and critical data. (Graham-Cumming, 2012)
- **Hash-based Message Authentication Code (HMAC):** To add authentication and integrity at the same time, the HMAC will be implemented. This is a cryptographic authentication technique that uses a hash function together with a secret key. This will verify that the data has not been tampered with during transit and that it comes from a legitimate source. (Okta, 2024) AWS uses this technique to protect the validity of signed tokens in its own systems, which reinforces the reliability of the approach. (AWS, n.d.)
- **Encryption in transit (TLS):** In this new Phone-me system, all traffic between clients and the server will be carried out via the HTTPS protocol, using the TLS 1.2 or 1.3 protocol, thus ensuring that data cannot be modified or intercepted during transmission. The necessary TLS certificates will be managed using AWS Certificate Manager. (AWS, n.d.)

Authentication mechanisms

Solution: Two-factor authentication

The term "**authentication**" in terms of security is a process of verifying the identity of a user. It helps to prevent unauthorised access to personal information and keep it private. To keep sensitive information more secure, **two-factor authentication** will be applied to access Phone-me's services.

Two-factor authentication (2FA) is a method that requires two forms of identification to gain access to data. There are many ways to apply 2FA: Hardware tokens, SMS verification, Push notifications, and Voice-based authentication ("What is two-factor authentication?", n.d.). To ensure that the users can access Phone-me's services remotely from their devices, '**SMS verification**', a process used to validate user identity by sending a text message containing a one-time unique password to user's registered mobile phone will be applied to the company's service.

Proposed SMS verification concept for Phone-me

Firstly, when the user attempts to login to Phone-me's website, the user will be prompted to enter his/her username and password from company's application. Password should be strong, minimum of 8 characters long with combinations of upper and lower letters, number(s) and at least one special character (e.g. !@#\$%^&*). Once the user successfully enters the username and corresponding password correctly, a second method of authentication SMS will be processed. If the user fails to login successfully, the system will display an error message saying the entered username and password do not match.

After the user has successfully entered a matching username and password, the system will take the user to a screen that prompts the user to enter a one-time randomly generated six-numbered password (OTP) which will be sent as a text message to user's personal mobile phone that is registered with user ID in Phone-me's database. After the user successfully enters the correct OTP, it will take them to a screen displaying user's Phone-me account where user can update his/her personal information and add or remove services he/she subscribed to Phone-me. If the user fails to enter the correct OTP, the system will give the options for user to re-enter another randomly generated one-time password that will be sent to his/her phone again. To gain access to the user's personal information from Phone-me's website, users must pass both authentication methods to gain access to personal information. This ensures that only the authorised user can get access to and safely update personal information stored in the company's database and kept private.

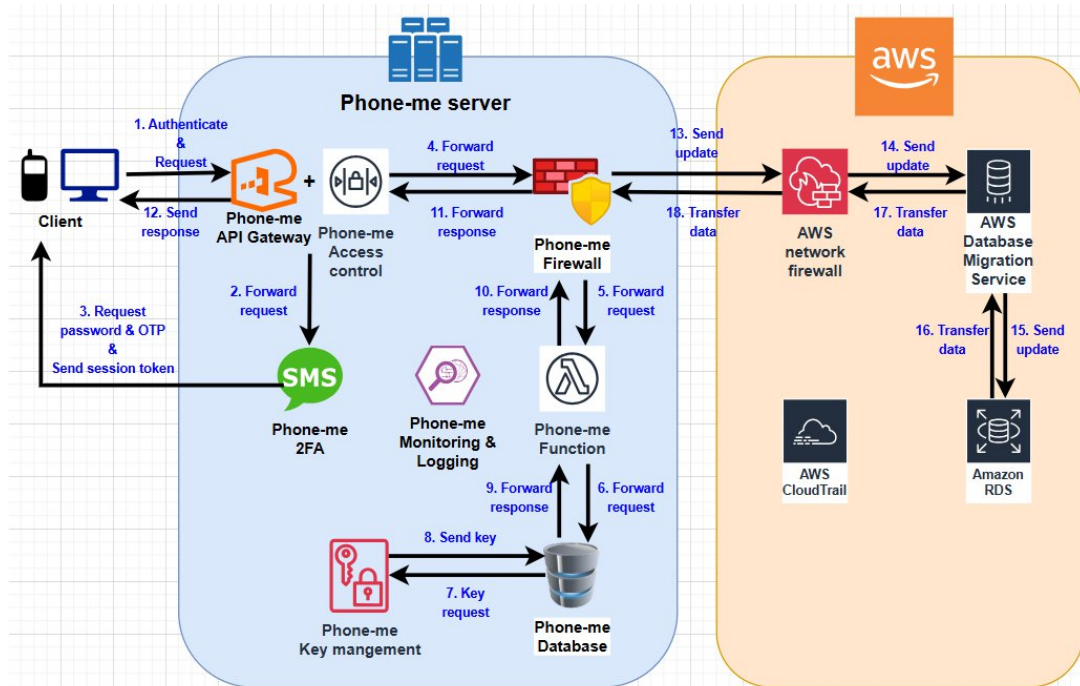
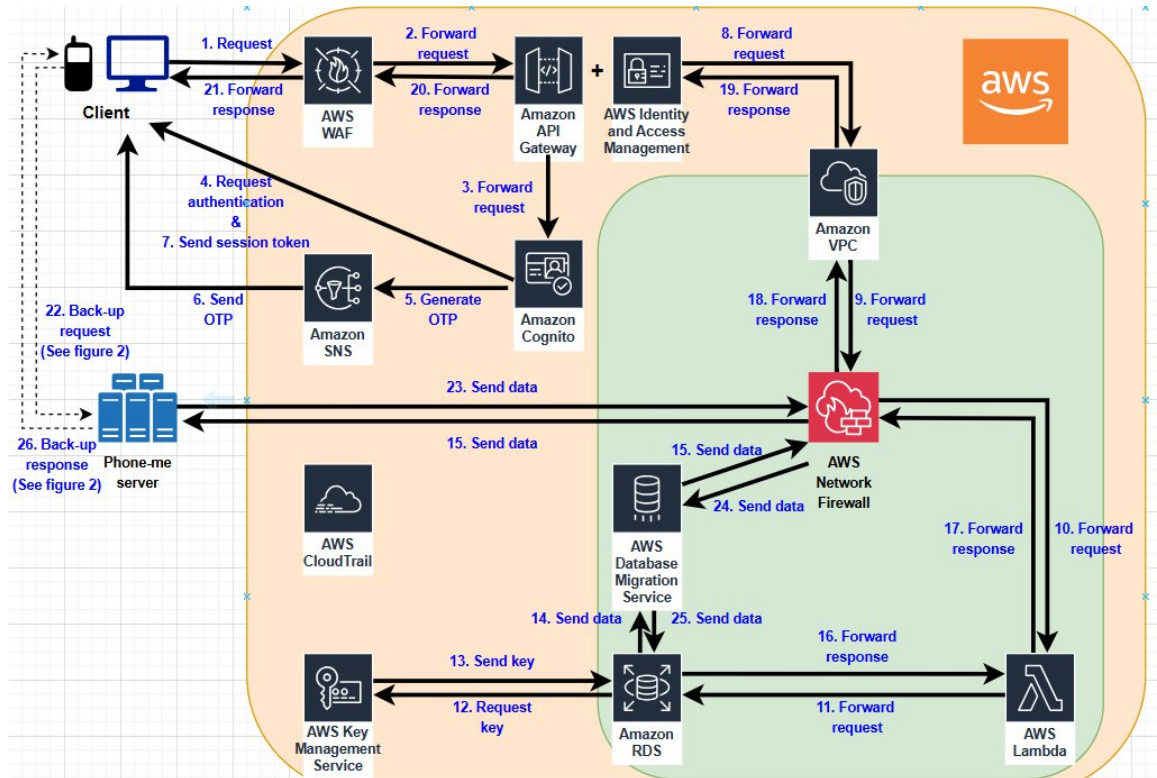
Task 3: Test platform

Question 1: Client-server platform design

The proposed system for the new Phone-me platform is based on a client-server architecture in which end-users remotely access a database hosted in the Amazon Web Services (AWS) cloud or Phone-me's back-up server when the AWS server goes offline. This architecture is composed as follows:

1. User opens up Phone-me's web application with desktop or mobile application with smartphone and requests access to personal information stored in **AWS RDS/Phone-me's database** that Phone-me saves customer data into.
2. User's request is first passed onto **AWS WAF** where filtering and monitoring HTTP and HTTPS request occur to protect from online threats such as SQL injection and then sent to **Amazon/Phone-me's API Gateway**, which acts as a front door of AWS/Phone-me's backend services.
3. **API Gateway/Phone-me's** sends user requests to **AWS RDS/Phone-me database** which sends response to user's end by prompting username and password.
4. All data exchanged between the user's mobile, or web application, and AWS backend services is encrypted in transit using the **Transport Layer Security (TLS)** protocol. This includes all HTTPS requests sent through **AWS WAF** and **API Gateway**, as well as communication between **API Gateway** and services such as **AWS Lambda, Cognito, IAM, and RDS**.
5. TLS ensures not only the confidentiality of user data but also its **integrity**, using cryptographic **message authentication codes (MACs)** to detect tampering during transmission.
6. After the user enters the username and password, this information is again sent through **AWS WAF, Amazon/Phone-me's API Gateway** and then to **AWS RDS**, to process verification.
7. If the username and password match, the second method, Short Message Service is processed. After **AWS RDS/Phone-me database** confirms that the user has successfully verified with matching username and password, it will send response to **AWS Lambda/Phone-me function** service to trigger **AWS Cognito/Phone-me 2FA** service to generate random six-numbered One Time Password (OTP) and forward it to user's device to enter this One-Time Password from their devices. After the user enters OTP, OTP is again sent through **AWS WAF, Amazon/Phone-me's API Gateway** and then to **AWS Cognito/Phone-me's SMS service** for verification. It will then check if the user entered OTP correctly and if it is correct, Cognito will send a 'session token' to user client and user can take this token to say 'I am verified user' at the **AWS/Phone-me's API Gateway** and get access to the AWS/Phone-me's backend.

8. At the gateway, it works with **AWS IAM/Phone-me's access control service** to identify what permissions that authenticated users have with the resources in Phone-me's AWS account.
9. After the user is assigned with permissions based on access control configuration in **AWS IAM** at **Amazon/Phone-me's API Gateway**, user's request is forwarded to **AWS/Phone-me's network firewall** inside **AWS VPC/Phone-me's database** of Phone-me's account. **Aws/Phone-me's network firewall** protects **VPC/Phone-me's database** resources by inspecting and filtering any suspicious traffic at the network level.
10. After the user's request passes **AWS/Phone-me's network firewall**, it is forwarded to **AWS Lambda/Phone-me's function service**, a core function of AWS/Phone-me's server which automatically handles all the server events.
11. After the user request is identified in **AWS Lambda/Phone-me's function service**, it fetches corresponding user data from **AWS RDS/Phone-me's database**, a database of all the Phone-me's users and sends response to the user's client.
12. **AWS RDS/Phone-me's database** works with **AWS KMS/Phone-me's key management service** which distributes and generates a key for encryption/decryption and send it to **AWS RDS/Phone-me's database** for encryption/decryption. (More detail in question 3).
13. User data in **AWS RDS** is regularly synchronised with database in **Phone-me's server** through **AWS DMS** to ensure that if AWS server goes offline, users can still remotely access their information stored in database in **Phone-me's server**.
14. All the activities happening on AWS/Phone-me's server are monitored and recorded by **AWS CloudTrail/Phone-me's monitoring & logging service** so that Phone-me can see who did what, when and from where.



Question 3: Symmetric key management algorithm

The algorithm chosen for encrypting communications is **AES-256 (Advanced Encryption Standard)** in **GCM (Galois/Counter Mode)**, a symmetric encryption algorithm due to its efficiency and security in network environments.

AES-GCM is an authentic encryption scheme. In addition to encrypting plaintext and decrypting it into ciphertext, it calculates an **authentication tag** based on the ciphertext and any additional data that requires authentication. (AWS, n.d.)

The **authentication tag** ensures that the data comes from the true source and that the ciphertext and **Additional Authentication Data (AAD)** have not been modified. (AWS, n.d.)

Advantages of AES-256 GCM:

- High speed in client-server environments.
- Integrity protection (integrated authentication).
- Natively supported by **AWS KMS**.

Technical Implementation:

1. When the user client sends requests to update personal information to AWS using Phone-me application, **AWS RDS** requests Data Encryption Key (DEK) from **AWS KMS** to encrypt updated information with AES-256 GCM algorithm.
2. **AWS KMS** generates Customer Master Key (CMK) for AES encryption of key and two keys: plaintext DEK and ciphertext DEK, an encrypted version of plaintext DEK to be saved with user data. **AWS KMS** then send these two keys to **AWS RDS**. Both keys have the same contents.
3. With plaintext DEK, **AWS RDS** uses AES-256 in GCM mode to encrypt updated user data.
4. When the user requests to view his data, **AWS RDS** uses saved ciphertext DEK to decrypt the user data and send it to the user client.
5. CMK is rotated regularly in **AWS KMS** to improve security.

Question 4: Key distribution

1. **AWS KMS** uses method called '**Envelope encryption**'. A method where plaintext DEK itself is encrypted and then sent to storage. This allows safe distribution of the key.
2. Before DEK is generated, **AWS KMS** creates a key called **Customer Master Key (CMK)** to encrypt one of DEK.
3. **CMK** is stored securely inside **AWS KMS** hardware security modules (HSMs) and never leaves **AWS KMS**.
4. **AWS KMS** then generates two copies of **Data Encryption Key (DEK)** for encrypting requested data in **AWS RDS**. One copy is 'plaintext DEK' for encrypting and decrypting immediately and one copy is 'ciphertext DEK' that is to be encrypted with CMK.
5. Both plaintext DEK and ciphertext DEK are sent to **AWS RDS**.
6. Plaintext DEK is destroyed after encryption.
7. When the user requests decryption, **AWS RDS** sends ciphertext key back to **AWS KMS** and it uses saved CMK to decrypt it back to plaintext key and then send it back to **AWS RDS** so that it can decrypt user data stored in **AWS RDS**.
8. After decryption, decrypted plaintext DEK that was used for user data decryption is destroyed.
9. All the keys are saved in AWS services and are not saved in user client.

Question 5: Two access control models analysis

1. RBAC (Role-Based Access Control)

This method restricts access based on the user's assigned role. Users who have access to AWS VPC of Phone-me's or Phone-me's server have different roles and have different permissions based on their roles. For example, only specific roles such as administrator can update user information, while other roles can only view logs. For Phone-me's security requirements, this approach can help to prevent unauthorised access by ensuring users have permissions (read, write, etc.) relevant to their role (auditor, administrator and user. It also works well with centralised identity systems like **AWS IAM** and supports multi-factor authentication (MFA).

2. ABAC (Attribute-Based Access Control)

This method allows dynamic access controls based on attributes. Attributes can be business hours, directory name, user location, IP address, and many more that can be configured with **AWS IAM** conditions based on company's security needs. Since Phone-me's service operates over New Zealand and

multifactor authentication, their service should not allow any access to their service for users from other countries.

Question 6: Access control model to the system

It is recommended to apply a hybrid approach by combining both RBAC as primary model with ABAC as secondary model in **AWS IAM** for Phone-me.

With RBAC, users are only able to perform tasks based on their roles:

- Auditor: Read-only access to user activity logs and system changes
- User: Can view and update their profiles and subscription
- Administrator: Full access to system configuration

With ABAC, allows dynamic control: only the people who have successfully completed 2FA can gain access to the server, during server maintenance, only administrators can gain access to the server, and only the people living in New Zealand can gain access to the server.

Technical implementation:

- Define user roles with RBAC (auditor, customer, administrator) and attach Identity and Access (**AWS IAM and Phone-me access control**) policies to the **AWS API gateway**.
- Add ABAC policies in **AWS IAM and Phone-me access control** to conditionally allow access to certain API functions based on user attributes (IP addresses from New Zealand only, and allows users to update accounts assigned to them only).
- Route requests to backend server based on permissions

Conclusion

To summarise, we must consider obligations, data integrity and two-factor authentication when creating a client-server platform for Phone-me. To address these issues, we decided to use AWS services to ensure no unauthorised people can gain access to sensitive user data and the data is stored safely and securely.

Business obligations we needed to consider were '**protection of user confidence**', '**service availability and security**', '**compliance with AWS security policies**', '**security incident management and response**'. For regulatory obligations, **principle 5: Storage and security of information of Privacy Act 2020** and **section 249, 250 and 252 of Crimes Act 1961** must be considered when designing the platform.

To ensure **data integrity**, user data is securely stored in AWS RDS and encrypted with a symmetric **AES-256 GCM** algorithm so that it remains confidential. The pair of keys used for AES-256 encryption/decryption for user data are generated from AWS KMS and both are distributed to AWS RDS. One key is used immediately for encryption and then discarded. Other pair of keys is encrypted with CMK in AWS KMS and stored in AWS RDS for future decryption. This method is called envelope encryption.

A combination of username and password with SMS is used for two-factor authentication to verify user with AWS Cognito and block unauthorised access. After the user is verified, access control is applied to the user based on the configuration of AWS IAM at the AWS API Gateway. A hybrid combination of RBAC and ABAC will be applied to allow certain permissions to only **specific roles** (read only for auditor, read and modify for customer, full control for administrator) who are **in New Zealand only** will be given access to user data.

Together, these implementations will enable us to create a secure, robust remote client-server platform and help us identify and block any unauthorised access.

References

- Lopez, T. (2023, February 03). *How to Make an Information Security Policy*. INNEVO. Retrieved from Innevo Blog: https://innevo-com.translate.google/blog/politica-de-seguridad-de-la-informacion?_x_tr_sl=es&_x_tr_tl=en&_x_tr_hl=es-419&_x_tr_pto=wapp
- Thurmond, T. (2024, February 6). *15 Information Security Policies Every Business Should Have*. KirkpatrickPrice. Retrieved from Kirkpatrick Price Blog: <https://kirkpatrickprice.com/blog/15-must-have-information-security-policies/>
- *Privacy Act 2020*. (2021, January). Privacy Commissioner. Retrieved from Office of the Privacy Commissioner. <https://privacy.org.nz/privacy-principles/>
- The Parliamentary Counsel Office. (2003, October 1). *Crimes Act 1961*. New Zealand Legislation. Retrieved from <https://www.legislation.govt.nz/act/public/1961/0043/170.0/DLM327382.html>
- *Sending information overseas*. (2021, June). Privacy Commissioner. Retrieved from Office of the Privacy Commissioner.
- <https://privacy.org.nz/assets/New-order/Your-responsibilities/Sending-information-overseas/1.-Principle-12-Guidance-web.pdf>
- *What is data integrity?* (2021, June 10). Acronis. Retrieved from Acronis: <https://www.acronis.com/en-us/blog/posts/data-integrity/>
- *What is blockchain technology?* (n.d.). SAP. Retrieved from SAP: <https://www.sap.com/canada/products/technology-platform/what-is-blockchain.html#page>
- *What is two-factor authentication?* (n.d.). Microsoft. Retrieved from
- <https://www.microsoft.com/en-nz/security/business/security-101/what-is-two-factor-authentication-2fa>
- CERT NZ. (n.d.). *Multi-factor authentication and verification*. Retrieved from Cert: <https://www.cert.govt.nz/information-and-advice/critical-controls/multi-factor-authentication/>
- Privacy Commissioner. (n.d.). *Your Responsibilities*. Retrieved from Office of the Privacy Commissioner: <https://www.privacy.org.nz/responsibilities/your-obligations/holding/>
- AWS. (n.d.). *What is Amazon Cognito?* Retrieved from Amazon Documentation: <https://docs.aws.amazon.com/cognito/latest/developerguide/what-is-amazon-cognito.html>
- AWS. (n.d.). *What is IAM?* Retrieved from AWS Documentation: <https://docs.aws.amazon.com/IAM/latest/UserGuide/introduction.html>

- AWS. (n.d.). *AWS Key Management Service*. Retrieved from Amazon Documentation:
<https://docs.aws.amazon.com/kms/latest/developerguide/overview.html>
- CERT NZ. (n.d.). *Security awareness building* . Retrieved from
<https://www.cert.govt.nz/information-and-advice/critical-controls/security-awareness-building/>
- Graham-Cumming, J. (2012, June 17). *Keeping passwords safe by staying up to date*. Retrieved from The Cloudflare Blog:
<https://blog.cloudflare.com/keeping-passwords-safe-by-staying-up-to-date/>
- Okta. (2024, August 28). *HMAC (Hash-Based Message Authentication Codes) Definition*. Retrieved from Okta: <https://www.okta.com/identity-101/hmac/>
- AWS. (n.d.). *Authenticating Requests: Using Query Parameters (AWS Signature Version 4)*. Retrieved from Amazon Documentation:
<https://docs.aws.amazon.com/AmazonS3/latest/API/sigv4-query-string-auth.html>
- AWS. (n.d.). *Security, identity, and compliance*. Retrieved from Amazon Documentation: <https://docs.aws.amazon.com/whitepapers/latest/aws-overview/security-services.html#aws-certificate-manager>
- AWS. (n.d.). *AWS KMS cryptography essentials*. Retrieved from AWS Documentation:
<https://docs.aws.amazon.com/kms/latest/developerguide/kms-cryptography.html>
- AWS. (n.d.). *Define permissions based on attributes with ABAC authorization*. Retrieved from AWS Documentation:
https://docs.aws.amazon.com/IAM/latest/UserGuide/introduction_attribute-based-access-control.html
- AWS. (n.d.). *Encrypting Data-at-Rest and Data-in-Transit*. Retrieved from AWS Documentation:
<https://docs.aws.amazon.com/whitepapers/latest/logical-separation/encrypting-data-at-rest-and--in-transit.html>